# SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad | Grup | Tarih

**Kavram:** SBOM = yazılım malzeme listesi · CVE = açığın kayıt no'su · CVSS = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: **bileşen var, sürüm etkileniyor, açık ulaşılabilir.**

## Verilen zafiyet kaydı

| | |
|---|---|
| **Bileşen** | PaketPro Component X (PLC firmware kütüphanesi) |
| **Sürüm** | 2.4 |
| **CVE** | CVE-XXXX-XXXX |
| **Önem** | Critical (CVSS 9.8) |
| **Yama** | Mevcut |

## Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

   Bileşen: var, SBOM'da PaketPro PLC firmware'inde Component X listeli. Sürüm: etkileniyor, 2.4 kayıttaki etkilenen sürümdür. Ulaşılabilirlik: var, uzak bakım modülü internete açık ve admin/admin ile korunuyor. Sonuç: bugünkü mimaride etkiliyor.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

   Hayır. Işık perdesi ve STO zinciri ayrı Safety PLC'de ve bu bileşenden bağımsız, çene/bıçak bölgesinde insan korunuyor. Önce telafi önlemi alınır (uzak bakımı kapat), yama planlı duruşta uygulanır. Sömürü izi görülürse üretim durdurulur.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

   Önce test. Aynı PLC modelinde yedek/test donanımında ya da simülasyonda denenir. Sonra planlı bakım duruşunda, proje yedeği alınıp geri dönüş planıyla üretim PLC'sine uygulanır.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

   Üretici sürüm notlarında Safety PLC veya ışık perdesi parametresi etkisi aranır; Safety program checksum'ı yama öncesi/sonrası karşılaştırılır. Yama sonrası ışık perdesi → STO ve kapak kilidi fonksiyon testi ile durma süresi ölçümü yapılır; Safety etkilenmişse yeniden validasyon gerekir.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

   Uzak bakım varsayılan kapalı + VPN, MFA ve jump server; admin/admin hesabı kapatılır; PLC'ye yalnızca izinli IP/port (firewall); USB kapatılır; PLC trafiği ve oturumlar izlenir; yama hazır olana kadar bakımda LOTO + güvenli düşük hız.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.